

Junior GRC Project – Cybersecurity Risk and Compliance Fundamentals

The goal of this project is to practice the fundamentals of the Governance, Risk, and Compliance (GRC) area in cybersecurity, and to apply the knowledge gained during my studies in a practical way using a fictional organization as an example.

1. Project Focus

The project focuses on the following areas:

- understanding risk-based thinking,
- reviewing basic incident management processes,
- understanding the role of Business Continuity and Disaster Recovery (BCP/DRP),
- gaining basic knowledge of national and European cybersecurity regulations (KiberTV, NIS2, ISO/IEC 27001, and CIS Controls).

The project presents the GRC approach through a fictional organization and was created for learning and portfolio purposes.

2. Organization Overview

The project is based on a fictional, medium-sized, state-owned organization.

Main characteristics of the organization:

- number of employees: approximately 200,
- type of operation: administrative and service-related activities,
- IT environment: a mixed use of on-premise systems and cloud-based services,
- types of data handled: personal data, operational data, and administrative documents.

The organization's cybersecurity goal is to ensure the confidentiality, integrity, and availability of information (*CIA triad*).

3. Basic Risk Assessment

The goal of the risk assessment is to identify cybersecurity threats that may affect the organization's operations and to understand their potential impact on information and services.

The project uses a simple risk assessment approach based on the likelihood and impact of each risk.

3.1 Identified Risks

The main cybersecurity risks affecting the organization are:

- Phishing attacks
- Unauthorized access
- Ransomware infection
- Data loss or data destruction
- Internal user errors or misuse (insider risk)

3.2 Risk Evaluation

For each identified risk, the following aspects are considered:

- likelihood of occurrence,
- potential impact,
- basic recommended security measures.

Phishing attacks

Likelihood: high

Impact: medium–high

Phishing attacks aim to trick users into revealing credentials. A successful attack may lead to unauthorized access or data loss.

Recommended measures:

- user awareness training,
- use of multi-factor authentication (MFA),
- encouraging users to report suspicious emails.

Unauthorized access

Likelihood: medium

Impact: high

Unauthorized access may allow internal or external actors to access sensitive systems or data.

Recommended measures:

- access control rules,
- regular access reviews,
- strong password policy.

Ransomware infection

Likelihood: medium

Impact: high

A ransomware attack can make systems unavailable and cause serious operational disruption.

Recommended measures:

- regular backups, including offline backups,
- applying updates and patches,
- endpoint protection solutions.

Data loss or data destruction

Likelihood: low–medium

Impact: high

Data loss may occur due to technical failures, human error, or cyberattacks.

Recommended measures:

- backup and recovery procedures,
- proper data storage,
- restricted access to sensitive data.

Insider risk

Likelihood: low–medium

Impact: medium–high

Internal users may cause security incidents intentionally or accidentally.

Recommended measures:

- minimizing user privileges,
- logging and monitoring,
- increasing security awareness.

Risk ID	Risk Description	Likelihood	Impact	Risk Level	Recommended Measures
R-01	Phishing attacks	High	Medium-High	High	User training, MFA
R-02	Unauthorized access	Medium	High	High	Access control, password policy
R-03	Ransomware infection	Medium	High	High	Backups, endpoint protection
R-04	Data loss	Low-Medium	High	Medium	Backup and recovery procedures
R-05	Insider risk	Low-Medium	Medium-High	Medium	Least privilege, logging

4. Incident Management Process

The purpose of the incident management process is to ensure that the organization can detect, handle, and minimize the impact of cybersecurity incidents in a timely manner.

A well-defined incident management process supports business continuity and compliance with internal and legal requirements.

4.1 Incident Management Steps

The organization handles cybersecurity incidents using the following basic steps:

- Incident detection
- Reporting the incident to the responsible person
- Information collection and analysis
- Response
- Recovery
- Post-incident review and documentation

4.2 Junior Role in Incident Management

At junior level, the role in incident management is mainly supportive:

- documenting incidents,
- assisting with information collection,
- maintaining incident logs,
- following internal procedures,
- supporting senior team members.

5. Business Continuity (BCP) and Disaster Recovery (DRP)

5.1 Business Continuity (BCP) – Basic Principles

The goal of business continuity is to ensure that critical activities can continue as quickly as possible after a cybersecurity incident or technical failure.

As part of the BCP, the organization identifies:

- critical business processes,
- critical IT systems,
- the business impact of system outages.

5.2 Disaster Recovery (DRP) – Basic Principles

The purpose of the Disaster Recovery Plan (*DRP*) is to restore IT systems and data after a serious incident or outage.

Key recovery aspects include:

- restoring data from backups,
- restarting systems,

- making services available again as soon as possible.

5.3 Junior Role in BCP/DRP

At junior level, involvement in BCP and DRP activities is mainly supportive and administrative:

- keeping documentation up to date,
- documenting recovery activities,
- recording observations during tests,
- supporting senior staff.

6. Regulatory and Compliance Approach

The purpose of this section is not to provide a legal analysis, but to show how cybersecurity compliance principles are applied in organizational operations.

6.1 Overview of Cybersecurity Regulations

The organization is affected by national and European cybersecurity regulations.

Relevant regulations for this project:

- Hungarian Cybersecurity Act (KiberTV),
- NIS2 Directive.

6.2 Compliance Principles

The organization follows these basic compliance principles:

- applying a risk-based approach,
- establishing and operating incident management processes,
- maintaining proper documentation,
- regular review and improvement,
- ensuring business continuity.

6.3 Junior Role in Compliance Activities

At junior level, the compliance role is mainly supportive and coordination-focused:

- maintaining compliance documents,
- following internal procedures,
- documenting risks and incidents,
- supporting audit preparation.

6.4 International Standards and Frameworks

In addition to legal requirements, the organization considers international standards and frameworks.

Relevant frameworks for this project:

- ISO/IEC 27001 Information Security Management System (ISMS),
- CIS Critical Security Controls (CIS Controls).

ISO/IEC 27001 provides a structured framework for identifying, managing, and documenting information security risks.

The CIS Controls offer practical technical and organizational security measures to reduce risks.

7. Project Summary

The goal of this junior GRC project was to present the basic concepts and approach of the Governance, Risk, and Compliance (GRC) domain in cybersecurity.

Through a fictional organization, the project demonstrated:

- identification and assessment of cybersecurity risks,
- basic incident management processes,
- the importance of business continuity and disaster recovery,
- regulatory and standards-based compliance awareness.

8. Personal Reflection

During the project, I had the opportunity to apply key GRC principles in a practical way.

I realized that the GRC domain is not mainly about technical solutions, but about identifying risks, setting priorities, and establishing appropriate processes and decisions.

The project was created for learning and portfolio purposes, based on my previous studies and knowledge. It helped me better understand the GRC approach and strengthened my interest in the risk management and compliance area of cybersecurity.

Created by:

Zsófia Viola Szabó